

SECURITY REVIEW

Prepared by Bizzly on behalf of HyrEvo

DOCUMENT

Revision History

Version	Description	Date
1.0	Final Release	28 Nov 2025
0.5	Document Review	27 Nov 2025
0.1	Document Draft	22 Nov 2025

Document Control

Document Title	HyrEvo Security Review
Client Name	HyrEvo
Project ID	HYRE-01
Classification	Commercial In Confidence
Prepared By	Daniel Draper, Bizzly

TABLE OF CONTENTS

DOCUMENT	2
Revision History	2
Document Control	2
TABLE OF CONTENTS	3
OVERVIEW	4
Executive Summary	4
Findings Summary	5
FINDINGS	6
User Enumeration in Login	6
Broken Access Controls	8
Path Traversal	11
CSRF Globally Disabled	13
Public Unauthenticated Upload	16
Vulnerable JavaScript dependency	18
Lack of Multi-Factor Authentication	20
Publicly Accessible PHP Information	21
PHP 8.2 - Security-Only Maintenance	23
ASSESSMENT DETAILS	25
Authorisation	25
Scope	25
Limitations	25
Legal	26
Responsible Disclosure & Ethics	26
APPENDIX	27
Vulnerability Definitions	27

OVERVIEW

Executive Summary

Overall Security Posture: **Needs Improvement**

Bizzly conducted a targeted web application security review of the HyrEvo platform to determine whether an unauthenticated or low-privileged user could access sensitive systems or data. The assessment was completed within a four-hour engagement window.

The review identified multiple high and critical risk vulnerabilities that significantly increase the likelihood of unauthorised access, system compromise and data exposure.

Additional weaknesses include broken access controls, the ability to enumerate valid users, the absence of Multi-Factor Authentication (MFA), exposure of debug information with restriction, and the use of outdated, vulnerable JavaScript libraries.

It is particularly concerning that HyrEvo is a newly developed platform but is already relying on outdated and vulnerable dependencies. This indicates that secure dependency management and secure development practices have not been embedded from inception, introducing unnecessary technical debt and expanding the attack surface early in the platform's lifecycle.

While PHP 8.2 remains in security-only support for now, we'd strongly suggest you plan an upgrade path well ahead of official support ending.

Overall, these findings point to weaknesses in secure configuration, access control enforcement and secure development best-practices. Immediate remediation of critical and high-risk items is required before the system can be considered suitable for production use or for handling sensitive data.

Security is an ongoing process, not a one-time event. To maintain and improve your security posture, it is recommended that the organisation:

- Conduct regular security assessments (at least annually)
- Implement secure coding practices and reviews
- Maintain vulnerability scanning and patch management
- Monitor logs and implement alerting mechanisms
- Perform change management with security review

Findings Summary

Reference	Description	Priority
HYRE-01-01	Public Unauthenticated Upload	Critical
HYRE-01-02	Broken Access Controls	High
HYRE-01-03	CSRF Globally Disabled	High
HYRE-01-04	Path Traversal	High
HYRE-01-05	Vulnerable JavaScript dependency	High
HYRE-01-06	Lack of Multi-Factor Authentication	High
HYRE-01-07	User Enumeration in Login	Medium
HYRE-01-08	Publicly Accessible PHP Information	Medium
HYRE-01-09	PHP 8.2 - Security-Only Maintenance	Info

FINDINGS

This section provides detailed descriptions of identified findings and supporting recommendations.

User Enumeration in Login

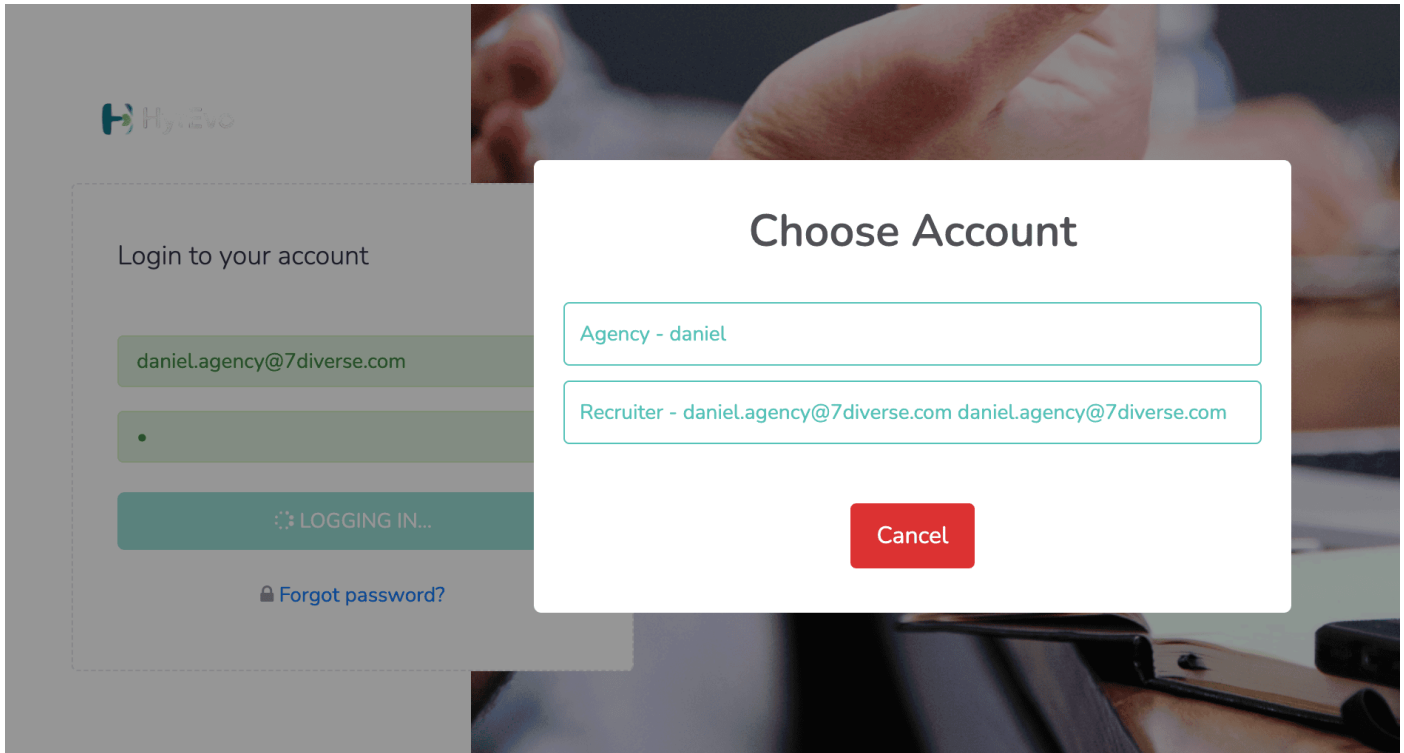
Severity	Medium
CVSS v4.0	6.9
CWE	CWE-204 , CWE-203 , CWE-200
OWASP	A01:2021 , A07:2021
Affected Component(s)	Authentication

Description

When an incorrect password is supplied for an existing account, the application displays a "Choose Account" modal rather than a generic authentication failure message. This behaviour allows an attacker to determine that the submitted username/email address is valid within the system.

By observing differences in server responses and UI behaviour between valid and invalid username, an attacker can enumerate existing accounts.

Evidence



Risk

This significantly reduces the barrier for targeted attacks such as:

- Credential stuffing
- Brute-force password attacks
- Social engineering / phishing
- Account takeover attempts

This vulnerability may allow an attacker to build a list of valid users without requiring authentication of elevated privileges.

Recommendation

1. Make the response identical for valid and invalid users by returning the same error message "Invalid username or password"
2. Move the "Choose Account" modal behind a successful authentication only
3. Add rate limiting
4. Add CAPTCHA, bot detection or exponential back-off after multiple failures

Broken Access Controls

Severity	High
CVSS v4.0	8.8
CWE	CWE-425 , CWE-284 , CWE-639 , CWE-200 , CWE-1031
OWASP	A01:2021 , A07:2021
Affected Component(s)	Candidates, Jobs, Agency Staff

Description

Bizzly identified that an authenticated user without the appropriate level of authorisation is able to access sensitive system resources by directly navigating to specific pages or endpoints. The affected resources include Candidates, Jobs, and Agency Staff.

By manually modifying the URL or accessing known paths, a user is able to bypass intended access controls and retrieve information outside of their permitted scope.

- Candidate and Agency Staff screens expose personal identifiable information (PII), including personal and contact details
- Job records expose business-sensitive information, including company details and compensation data

This indicates a failure in effective server-side authorisation enforcement, allowing a user to access objects that they do not own and are not permitted to view — a condition commonly known as Insecure Direct Object Reference (IDOR) or Broken Object Level Authorisation (BOLA).

While the user must first authenticate, no additional privilege level is required to exploit the issue once logged in. This increases the risk of unauthorised data access, privacy breaches, and regulatory exposure, and may place the organisation at risk of non-compliance with data protection obligations.

Resolving this requires enforcing strict server-side authorisation checks to ensure that every resource request is validated against the user's role, tenant, and context — regardless of how the request is initiated.

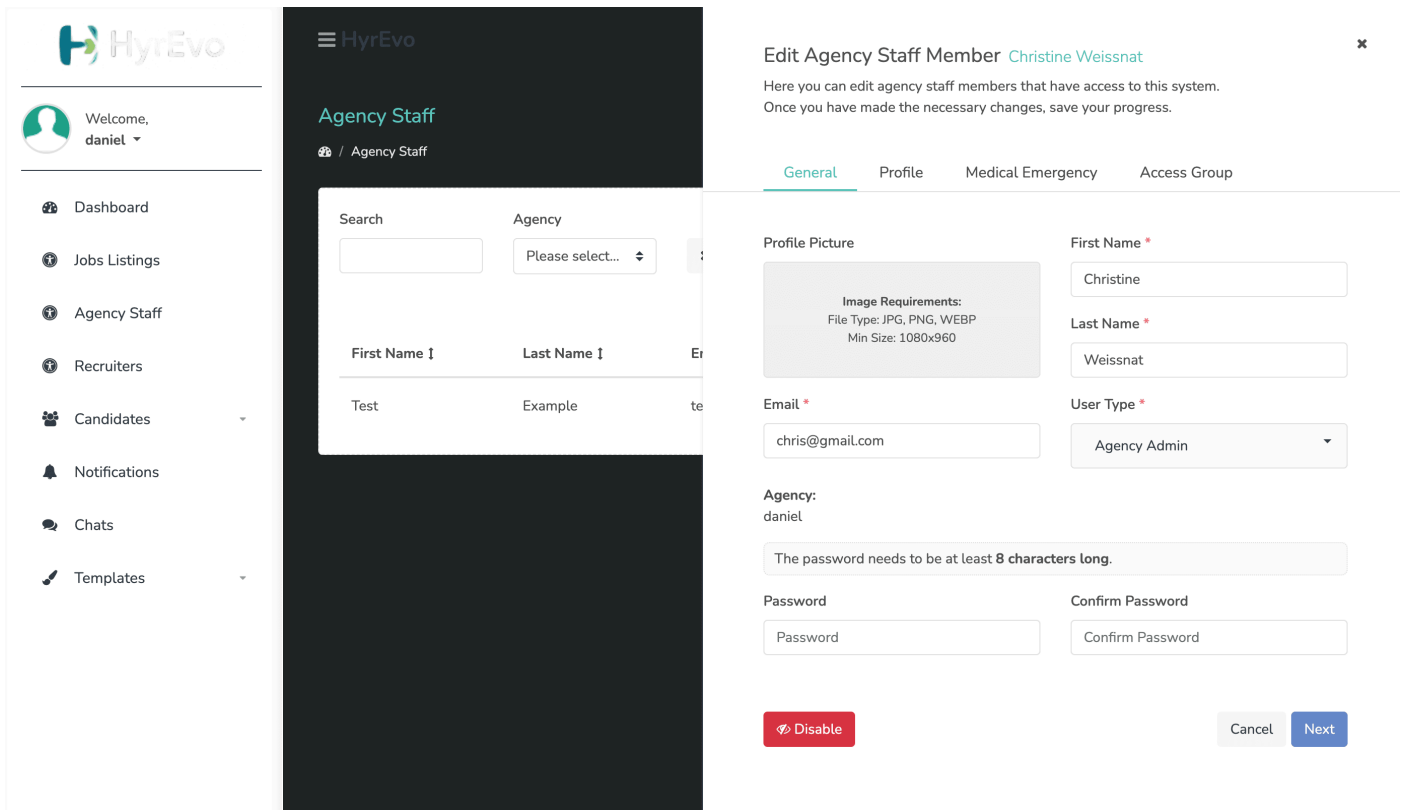
Risk

- Privacy breaches of Candidate and Staff PII
- Unauthorised access to commercially sensitive remuneration data
- Increased likelihood of data leakage or abuse
- Possible regulatory non-compliance (e.g. Privacy Act, GDPR, contracts)
- Reputational harm if disclosed
- Enables mass data harvesting with simple automation

Because the vulnerability requires only a basic account, even a low-skilled attacker could exploit it to extract significant volumes of sensitive information.

Evidence

The screenshot displays the HyrEvo web application interface. On the left is a sidebar with the HyrEvo logo, a user profile for 'daniel.agency@7diverse.com', and navigation links for Dashboard, Jobs, Candidates (highlighted), Candidate Resume Listings, Notifications, and Chats. The main content area is titled 'Candidates' and includes an 'Add candidate' button. The 'Edit Candidate' form for 'Testtest Testtest' is shown with tabs for Personal Details, Professional Info, Application, and Agency & Job. The 'Personal Details' tab is active, containing fields for Reference Number (CAND-202511-0021), Email (testtest@testtest.com), First Name (testtest), Last Name (testtest), Phone, ID Number, Date of Birth, Gender (a dropdown menu), and Address.



Recommendation

1. Review and enforce server-side authorisation checks for ALL resources
2. Validate access based on:
 - a. User role (RBAC)
 - b. Tenant / organisation
 - c. Object ownership
 - d. Relationship to the record
3. Apply deny-by-default logic
4. Scope all queries to the tenant/account, preferably done at the database layer using something like Row-Level Security (RLS) available in PostgreSQL. However, for MySQL this isn't available and instead a `WHERE` clause on every query would be sufficient.

Path Traversal

Severity	High
CVSS v4.0	8.5
CWE	CWE-23 , CWE-434 , CWE-59 , CWE-732
OWASP	A05:2021 , A01:2021 , A08:2021
Affected Component(s)	File uploads

Description

The application implements an image upload and thumbnail generation feature using server-side image processing (GD/Cropper). However, the filename and/or path used as the thumbnail output destination (\$thumb_image_name) is derived from unsanitised user input, and is used directly in file system write operations and permission changes.

```
1 imagejpeg($newImage, $thumb_image_name, 70);
2 chmod($thumb_image_name, 0777);
```

No validation or canonicalisation is performed to ensure the output path remains within the intended upload directory.

As a result, a user can supply traversal sequences (e.g. `../`) or absolute/relative paths that allow the server to:

- Write image content to arbitrary files
- Overwrite existing system or application files
- Modify file permissions of those files
- Affect other users' data, configuration files, or application behaviour

This vulnerability is not limited to uploaded images themselves, but to any file that the web server user has write access to.

Severity escalation conditions (Critical – CVSS 9.4–9.8)

- Web server runs as root or elevated user
- Upload directory resides within system or shared directories
- Application is multi-tenant

- Sensitive system or configuration files are writable
- Application shares volume with backups or configuration storage

Evidence

Using a controlled test in an isolated environment to demonstrate arbitrary file modification:

1. Create a test file on the server

```
1  mkdir -p /tmp/thumb-test
2  echo "ORIGINAL CONTENT" > /tmp/thumb-test/canary.txt
3  chmod 600 /tmp/thumb-test/canary.txt
```

2. Manipulate the application and set:

```
1  $thumb_image_name = '../../tmp/thumb-test/canary.txt'
```

This simulated user-controlled path traversal.

3. Normal image upload was performed using any standard PNG or JPEG image.
4. Expected outcome:
 - a. File contents will contain binary image data
 - b. File permissions will be 0777
 - c. File integrity is compromised outside intended directory

Risk

An attacker (or low-privileged authenticated user) could:

- Overwrite another user's files
- Overwrite application assets (JS, CSS, images)
- Corrupt backups or data files
- Change permissions of sensitive files to world-writable (0777)
- Potentially escalate to remote code execution in misconfigured environments

Although the image is re-encoded by the cropper (which removed embedded payloads such as EXIF PHP polyglots), path traversal and arbitrary file overwrite remain fully exploitable even after re-encoding.

This makes the issue particularly severe as exploitation does not require code execution to be demonstrated to prove impact.

Recommendation

1. Remove user control over output paths, instead:

```
1 $safeDir = '/var/app/uploads/thumbnails';
2 $name = bin2hex(random_bytes(16)) . '.jpg';
3 $thumbPath = $safeDir . DIRECTORY_SEPARATOR . $name;
```

2. Enforce path restriction

```
1 $realBase = realpath($safeDir);
2 $realDest = realpath(dirname($thumbPath));
3
4 if ($realDest === false || strpos($realDest, $realBase) !== 0) {
5     throw new Exception("Illegal path detected.");
6 }
```

3. Remove `chmod 0777`, replace with:

```
1 chmod($thumbPath, 0644);
```

4. Ensure uploads are store outside of web root
5. Ensure PHP execution is not enabled in upload directories
6. Ensure re-encoding remains in place

CSRF Globally Disabled

Severity	High
CVSS v4.0	9.3
CWE	CWE-352
OWASP	A01:2021
Affected Component(s)	Configuration

Description

Cross-Site Request Forgery (CSRF) protection appears to be globally disabled in the application configuration.

```
1  $config['csrf_protection'] = false;
```

This configuration applies across the entire application and prevents the framework from validating the authenticity of incoming state-changing requests. As a result, the application does not verify that requests originate from trusted, user-initiated sources.

Without CSRF protection, attackers can force authenticated users to unknowingly perform sensitive actions via a crafted external website, email, or embedded content.

This vulnerability affects all authenticated users, including administrators.

Any state-changing endpoint is at risk, including but not limited to:

- Password resets
- Account modifications
- User creation / deletion
- Administrative actions
- Data modifications or deletion
- Role and permission changes

Because authentication cookies are automatically sent by the browser, the application cannot distinguish legitimate actions from attacker-initiated requests.

Evidence

The following line was observed in the application configuration:

```
1  $config['csrf_protection'] = false;
```

With this setting disabled:

- No CSRF token is generated for forms
- No CSRF token is validated on submission
- Any external site can submit a forged request on behalf of an authenticated user

This means a malicious actor can construct an external page that silently submits a request such as:

- Changing the victim's email address

- Resetting a password
- Granting themselves administrative access
- Deleting data
- Modifying critical records

No warning or confirmation is shown to the user, as the browser believes the request is legitimate.

Risk

An attacker could:

- Force users to perform actions without their knowledge
- Reset password or take over accounts
- Modify or delete business-critical data
- Elevate privileges to administrator level
- Perform destructive actions while appearing as a legitimate user

This creates a high likelihood of account compromise, data loss, and regulatory or reputational damage.

The only user requirement is that the victim is currently logged in when visiting a malicious page.

Recommendation

1. Enable CSRF protection globally in application/config/config.php

```
1 $config['csrf_protection'] = true;
```

2. Ensure CSRF tokens are generated per request (recommended for PHP 8.2+)

```
1 $config['csrf_regenerate'] = true;
```

3. Confirm all forms output a CSRF token (example CodeIgniter style)

```
1 <input
  type="hidden"
  name="<?= $this->security->get_csrf_token_name(); ?>"
  value="<?= $this->security->get_csrf_hash(); ?>"
>
```

4. Restrict CSRF exemptions:

- a. Are called by trusted external services
- b. Cannot carry a CSRF token (e.g. Stripe, Twilio)
- c. Are protected by an alternate method (HMAC, IP allowlist, secret key, etc.)

Public Unauthenticated Upload

Severity	Critical
CVSS v4.0	10.0
CWE	CWE-23 , CWE-434 , CWE-59 , CWE-732
OWASP	A05:2021 , A01:2021 , A08:2021
Affected Component(s)	File uploads

Description

The application exposes publicly accessible, unauthenticated file upload endpoint for debugging. There are also a couple of additional functions that may be vulnerable.

These endpoints do not require authentication, authorisation, or role validation before processing upload requests. As a result, any remote, unauthenticated user can invoke these endpoints directly.

This provides a direct and reliable path to:

- Remote file upload
- Arbitrary file hosting
- Potential remote code execution (RCE)
- Malware hosting and distribution
- Webshell deployment

Evidence

It was possible to upload arbitrary files successfully

```
1 curl -s -X POST
"https://www.shoesmith.hyrevo.com.au/browser/ajax_upload_file" -F
"ckfiles[]=@poly.png;type=image/png"
```


A success response was provided for various files

```
1
{"success":true,"csrf":null,"hasWarnings":false,"isSuccess":true,"w
arnings":[],"files":[{"date":"Wed, 26 Nov 2025 10:45:45
+0200","extension":"png","file":"resources\ckuploads\OSNydrA1TcgZ
.png","name":"OSNydrA1TcgZ.png","old_name":"poly.png","old_title":"
poly","replaced":false,"size":191,"size2":"0.19
KB","title":"OSNydrA1TcgZ","type":"image/png","uploaded":true}]]}%
```

No authentication headers, tokens, or session cookies are required for successful upload and storage of files via this endpoint. This could likely be chained with something like a path traversal vulnerability.

Risk

A remote attacker could:

- Upload arbitrary files without authentication
- Upload webshells or executable scripts
- Upload malware or phishing content
- Host illegal or malicious content on the organisation's domain
- Upload large files to exhaust disk space (storage-based DoS)
- Chain with other vulnerabilities to escalate privileges or pivot internally

In environments where the uploads directory allows script execution, this vulnerability **directly enables Remote Code Execution (RCE)**.

Even in environments where script execution is disabled, this still represents a:

- Major brand risk (malicious content hosted on official domain)
- Legal risk (illegal content distribution)
- Storage and infrastructure risk (DoS via large uploads)
- Trust & reputation risk

Because this is fully unauthenticated and exploitable by anyone on the internet, the risk is categorised as **CRITICAL**.

Recommendation

1. Remove user control over output paths, instead:

```

1 $safeDir = '/var/app/uploads/thumbnails';
2 $name = bin2hex(random_bytes(16)) . '.jpg';
3 $thumbPath = $safeDir . DIRECTORY_SEPARATOR . $name;

```

2. Enforce path restriction

```

1 $realBase = realpath($safeDir);
2 $realDest = realpath(dirname($thumbPath));
3
4 if ($realDest === false || strpos($realDest, $realBase) !== 0) {
5     throw new Exception("Illegal path detected.");
6 }

```

3. Remove `chmod 0777`, replace with:

```

1 chmod($thumbPath, 0644);

```

4. Ensure uploads are store outside of web root
5. Ensure PHP execution is not enabled in upload directories
6. Ensure re-encoding remains in place

Vulnerable JavaScript dependency

Severity	High
CVSS v4.0	8.2
CWE	CWE-1104
OWASP	A06:2021
Affected Component(s)	JavaScript Libraries

Description

The application is using an outdated JavaScript versions on one or more pages. Older libraries can contain multiple publicly documented vulnerabilities including Cross-Site Scripting (XSS).

Because some of the libraries such as jQuery are a foundational dependency, any vulnerable functions (e.g. `.html()`), DOM manipulation APIs, or unsafe handling of HTML fragments /

selectors) may be reachable via existing application code or third-party plugins. If an attacker can control any data that flows into these APIs, they may be able to execute arbitrary JavaScript in a user's browser.

In practice, this can allow attackers to:

- Steal session tokens or other sensitive data from the browser
- Perform actions on behalf of the victim (CSRF-style behaviour via script)
- Inject phishing or credential-harvesting content into the page
- Modify the behaviour of the UI in ways that mislead users

Because the jQuery versions in use has known vulnerabilities with public proof-of-concepts, it should be treated as a known vulnerable component, even if a direct exploit path has not yet been demonstrated in this specific application.

Evidence

Library	Request	Version	Reference
jQuery	Link	v2.2.4	Snyk - jQuery
jQuery	Link	v3.3.1	Snyk - jQuery
jQuery UI	Link	v1.12.1	Snyk - jQuery UI

Risk

- Compromise of user accounts (via session theft or token exfiltration)
- Exposure or manipulation of sensitive data displayed in the browser
- Fraudulent actions executed under a victim's authenticated session
- Potential regulatory/compliance impact if personal or sensitive data is exposed

Recommendation

1. Update JavaScript libraries to the latest supported version. Additionally ensure the affected applications are included as part of a regimented patching and update process.
2. Establish a dependency management process that includes a regular review and update. Where possible utilise automated dependency detection and update tools.
3. Remove duplicate libraries, especially older versions.
4. Ensure a Content Security Policy exists to reduce the impact of any XSS that remains:
 - a. Disallow inline scripts where feasible

- b. Restrict script sources to trusted origins

Lack of Multi-Factor Authentication

Severity	High
CVSS v4.0	8.7
CWE	CWE-308 , CWE-287
OWASP	A07:2021
Affected Component(s)	

Description

The application currently relies solely on single-factor authentication (username and password) to grant access to user accounts. There is no enforcement or option for Multi-Factor Authentication (MFA) such as Time-based One-Time Passwords (TOTP), hardware security keys (WebAuthn/FIDO2), or out-of-band verification (e.g. email or SMS OTP).

Passwords alone are routinely compromised through credential stuffing, phishing, database breaches, or brute-force attacks. Without a secondary factor, an attacker who obtains valid credentials will be granted full access to the account with no further resistance.

This significantly weakens the organisation's overall authentication posture and increases exposure to account takeover (ATO), data theft and privilege abuse.

Evidence

1. Login only prompts for username and password
2. No additional verification step is presented after successful password authentication
3. No MFA enrolment or enforcement options are available for the user to configure

Risk

The absence of MFA materially increases the risk of:

- Account takeover (ATO) following credential leakage
- Unauthorised access to PII and sensitive data
- Privilege escalation if an administrative account is compromised

- Business process manipulation (e.g. jobs, candidates, invoices, payments)

Regulatory and compliance exposure under frameworks requiring strong authentication (e.g. ISO 27001, NIST 800-63, Essential Eight, PCI DSS, GDPR Article 32)

In systems typically accessed over the internet, this vulnerability is frequently exploited using automated tooling and breached-credential databases, making it a high-likelihood and high-impact issue.

Recommendation

Implement and enforce Multi-Factor Authentication (MFA) across all user accounts, with special emphasis on privileged roles.

- Preference would be to implement WebAuthn / Passkeys
- Additionally TOTP (RFC 6238) with backup/recovery codes
- MFA should be required when:
 - High-risk logins based on location / IP / device
 - Sensitive accounts (admins, users with financial access, etc.)

Publicly Accessible PHP Information

Severity	Medium
CVSS v4.0	6.9
CWE	CWE-200
OWASP	A05:2021
Affected Component(s)	

Description

A publicly accessible PHP Information page (`phpinfo()`) was identified at the following endpoint:

```
1 https://www.shoesmith.hyrevo.com.au/n.php
```

The page exposes full server configuration details including (but not limited to):

- PHP version and build information

- Operating system and server host details
- Enabled PHP modules and extensions
- Server paths and directory structures
- PHP configuration directives (e.g. memory limits, file upload settings, include paths)
- Loaded extensions such as MySQL, LDAP, GD, OpenSSL, cURL, XML, etc.

This level of detail significantly lowers the difficulty of a targeted attack by enabling an attacker to fingerprint the environment, identify known vulnerabilities for specific modules/versions, and tailor exploits to the exact configuration of the target server.

Evidence

PHP Version 8.2.29 	
System	Linux s3367.syd1.stableservers.net 4.18.0-553.8.1.lve.el8.x86_64 #1 SMP Thu Jul 4 16:24:39 UTC 2024 x86_64
Build Date	Sep 18 2025 10:21:08
Build System	Linux buildfarm05-new.corp.cloudlinux.com 4.18.0-553.8.1.el8_10.x86_64 #1 SMP Tue Jul 2 07:26:33 EDT 2024 x86_64 x86_64 x86_64 GNU/Linux
Configure Command	'./configure' '--build=x86_64-redhat-linux-gnu' '--host=x86_64-redhat-linux-gnu' '--program-prefix=' '--disable-dependency-tracking' '--prefix=/opt/cpanel/ea-php82/root/usr' '--exec-prefix=/opt/cpanel/ea-php82/root/usr' '--

Risk

Exposing the PHP information page introduces the following risks:

- Targeted Attack Enablement – Attackers can search for known vulnerabilities specific to the exposed PHP version and enabled modules.
- Path & Environment Disclosure – Reveals directory structure, temporary paths, and include locations that can facilitate file inclusion and traversal attacks.
- Increased Attack Surface Awareness – The list of installed modules assists attackers in customising exploit payloads.
- Chaining Vulnerabilities – If file upload, LFI/RFI, or other vulnerabilities exist elsewhere on the site, this information makes exploitation significantly easier.
- Reconnaissance Value – The site becomes a higher-value target due to detailed system fingerprinting data being publicly available.

While phpinfo itself is not an exploit, it is a valuable intelligence resource for attackers and is widely considered unsafe to expose in production environments.

Recommendation

- Immediately remove or disable the /n.php file from the production environment.
- If diagnostic access is required, restrict via authentication or IP allow-listing.

- Review webroot for any other test, debug, or legacy files containing sensitive system information.
- Minimise attack surface by disabling unused PHP extensions.
- Ensure production configuration does not expose debugging pages, stack traces, or system info.
- Consider adding automated checks to prevent debug files being deployed to production in future releases.

PHP 8.2 – Security-Only Maintenance

Severity	Info
CVSS v4.0	
CWE	
OWASP	
Affected Component(s)	

Description

- The release branch PHP 8.2 entered “security-fixes only” mode after active support ended on 31 December 2024.
- Official policy indicates that full support — both bug fixes and security patches — for PHP 8.2 will end with its EOL date in December 2026. (After that, 8.2 will be unsupported.)

Evidence

PHP Version 8.2.29 	
System	Linux s3367.syd1.stableservers.net 4.18.0-553.8.1.lve.el8.x86_64 #1 SMP Thu Jul 4 16:24:39 UTC 2024 x86_64
Build Date	Sep 18 2025 10:21:08
Build System	Linux buildfarm05-new.corp.cloudlinux.com 4.18.0-553.8.1.el8_10.x86_64 #1 SMP Tue Jul 2 07:26:33 EDT 2024 x86_64 x86_64 x86_64 GNU/Linux
Configure Command	'./configure' '--build=x86_64-redhat-linux-gnu' '--host=x86_64-redhat-linux-gnu' '--program-prefix=' '--disable-dependency-tracking' '--prefix=/opt/cpanel/ea-php82/root/usr' '--exec-prefix=/opt/cpanel/ea-php82/root/usr' '--

Currently Supported Versions

Branch	Initial Release		Active Support Until		Security Support Until		Notes
8.1	25 Nov 2021	<i>4 years ago</i>	25 Nov 2023	<i>2 years ago</i>	31 Dec 2025	<i>in 1 month</i>	Migration guide for PHP 8.1
8.2	8 Dec 2022	<i>2 years, 11 months ago</i>	31 Dec 2024	<i>10 months ago</i>	31 Dec 2026	<i>in 1 year, 1 month</i>	Migration guide for PHP 8.2
8.3	23 Nov 2023	<i>2 years ago</i>	31 Dec 2025	<i>in 1 month</i>	31 Dec 2027	<i>in 2 years, 1 month</i>	Migration guide for PHP 8.3
8.4	21 Nov 2024	<i>1 year ago</i>	31 Dec 2026	<i>in 1 year, 1 month</i>	31 Dec 2028	<i>in 3 years, 1 month</i>	Migration guide for PHP 8.4
8.5	20 Nov 2025	<i>6 days ago</i>	31 Dec 2027	<i>in 2 years, 1 month</i>	31 Dec 2029	<i>in 4 years, 1 month</i>	Migration guide for PHP 8.5

Risk

While 8.2 remains under security-only support, no new feature development or non-security bug fixes will be provided. This reduces flexibility for future upgrades or improvements.

After December 2026, using PHP 8.2 will carry increased risk: any newly discovered security vulnerabilities will not be patched.

For long-lived projects or new development, continuing to rely on 8.2 may lead to technical debt and maintenance burden.

Compatibility with newer PHP versions, libraries or frameworks may degrade over time — particularly as ecosystem moves forward with newer releases.

Recommendation

Plan and migrate to a current supported PHP version, ideally well before end-of-support.

ASSESSMENT DETAILS

The following section outlines the details specific to the engagement described within this report.

Authorisation

This security assessment was conducted with the explicit authorisation of the system owner or authorised representative of:

Organisation	HyrEvo
Assessment Dates	November 2025 - December 2025
Authorised By	Buster Shoesmith, Director, 0476 234 591

Scope

Bizzly was commissioned by Buster Shoesmith to perform a web application security review of the HyrEvo environment. Bizzly was given 4 hours to complete the review, we were unable to complete a full review in the time permitted.

The aim of the assessment was to determine if either an authenticated or unauthenticated attacker could gain access to the environment or any information that may be considered sensitive in nature.

The following table details the resources targeted during the engagement:

Engagement Targets
https://www.shoesmith.hyrevo.com.au/

Limitations

This assessment was performed within a limited time frame and based on the specific scope defined in the engagement agreement. As such, it is not an exhaustive assessment of all possible security vulnerabilities.

The findings represent conditions observed at the time of testing only. System modifications, new application features, infrastructure changes, or newly discovered attack techniques may introduce additional risks after this report is issued.

For ongoing protection, regular security assessments, code reviews, patching, and monitoring should be implemented as part of a continuous security program.

Legal

This report is provided for the sole use of the authorised organisation identified in this agreement. The information contained in this report:

- Is confidential
- Must not be distributed to third-parties without written permission
- Must not be used as the sole basis for legal, regulatory, or procurement decisions
- Does not constitute a warranty, guarantee, or certification of security

To the maximum extent permitted by law, the author(s) and organisation performing this assessment accept no liability for:

- Damages arising from the use or misuse of this report
- Vulnerabilities not discovered during the assessment
- Changes made to systems after the assessment date
- Actions taken by third-parties based on this information

Responsible Disclosure & Ethics

All testing was conducted in line with responsible disclosure principles:

- No unnecessary harm to systems or data was caused
- Sensitive data was not exfiltrated beyond what was required to demonstrate risk
- Proof-of-concept testing was designed to be non-destructive and reversible where possible
- Any critical issues discovered were disclosed to the client as soon as reasonably practicable.

APPENDIX

Vulnerability Definitions

CVSS v4.0: "How bad is this, really?"

The Common Vulnerability Scoring System (CVSS) is there to answer one simple question:

How urgently does this need to be fixed compared to everything else?

In CVSS v4.0, the vulnerability score is calculated using a set of metric groups that describe both the nature of the vulnerability and the potential impact.

The Base Metric represents the fundamental characteristics of the vulnerability, including how it can be exploited and the technical impact on the affected system. These attributes do not change over time.

CVSS v4.0 also introduces additional metric groups that capture context and real-world conditions, such as how the vulnerability might affect related or connected systems, or whether specific environmental factors reduce or increase the overall risk.

This structure allows organisations to adjust the final severity based on where and how the vulnerable system is deployed in their environment, providing a more accurate reflection of real-world risk.

Bizzly will provide the Base and Supplemental Metrics to compile a score that will reflect the severity and risk. This score does not consider any environmental controls that might be in place.

The CVSS score can be mapped to a bug severity, these are shown in the following table:

CVSS	Rating	Severity	Description
9.0 - 10.0	Critical	Sev 1	Likely to cause a serious incident: data breach, major outage, or regulatory impact. Exploitation is straightforward and/or already observed in the wild. Requires immediate, same-day response and executive visibility.
7.0 - 8.9	High	Sev 2	Significant risk to the business if exploited. Could lead to unauthorised access, service

			disruption, or exposure of important data. Should be prioritised for remediation in the next release or within a defined short time frame.
4.0 - 6.9	Medium	Sev 3	Noticeable risk but typically requires specific conditions or chaining with other issues. Impact is limited in scope (e.g. a subset of users or non-critical systems). Address as part of normal planned work.
0.1 - 3.9	Low	Sev 4	Low likelihood or low impact. Hard to exploit in practice or would only cause minor inconvenience. Suitable for backlog / hardening work when higher risks are addressed.
0.0	Info	Sev 5	Not a direct vulnerability. Typically configuration notes, best-practice recommendations, or design observations. No immediate risk; implement when convenient.

For more information refer to the [CVSS specification documentation](#).

CWE: "What kind of mistake did the developer make?"

Common Weakness Enumeration (CWE) is there to answer:

What is the actual programming/design mistake here?

Developers don't fix "vulnerabilities" they fix code patterns. This results in "you have this type of weakness in your codebase" instead of "this thing is bad", which is far more useful for engineering.

OWASP: "Why should the business care?"

OWASP maps technical findings to top business risks:

- A01 Broken Access Control
- A02 Cryptographic Failures
- A03 Injection
- A04 Insecure Design

- A05 Security Misconfiguration
- A06 Vulnerable and Outdated Components
- A07 Identification and Authentication Failures
- A08 Software and Data Integrity Failures
- A09 Security Logging and Monitoring Failures
- A10 Server Side Request Forgery (SSRF)

Glossary

Term	Meaning
CWE	Common Weakness Enumeration
CVSS	Common Vulnerability Scoring System
OWASP	Open Worldwide Application Security Project
MFA	Multi-Factor Authentication
TOTP	Time-based One-Time Password

THANK YOU!

We look forward to helping make a positive
difference in the way you do business.

Bizzly